

Windows SSH Brute Force Attack

Threat Detection & Root Cause Analysis Using Wazuh

Prepared By: *Aaliya Khalil Khatib*

Prepared For: *XXXXXXXXX*

Table of Contents

1. Executive Summary	3
2. Lab Architecture	3
3. Environment Validation	3
4. Attack Scenario & MITRE Mapping	5
5. Log Collection & Monitoring	6
6. Root Cause Analysis	8
7. Indicators of Compromise (IOCs)	9
8. Recommendations & Mitigations	9

1. Executive Summary

The attacker using the Kali Linux machine (**IP:10.0.2.X**) performs reconnaissance to gather information about all open ports on the Windows victim machine (**IP:10.0.2.X**). When it is observed that the **SSH (port 22)** service is open on the machine, the attacker attempts a **brute-force SSH attack** against the victim using 'Hydra'. After obtaining the SSH session password, the attacker uses it to SSH into the victim's machine and successfully gain access to the Windows environment. The attack was successfully executed using a limited set of passwords, demonstrating that weak authentication controls can lead to compromise even with low-complexity attacks.

2. Lab Architecture

The following VMs were set up for this analysis:

- Ubuntu VM (Wazuh Server installed here)
- Windows VM (Wazuh Agent is installed here. Acts as the victim machine)
- Kali Linux (The attacker machine)

IP addresses of the VMs:

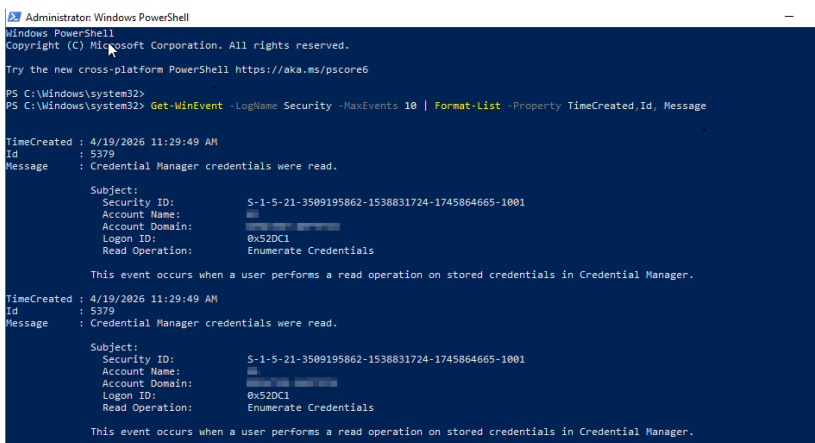
- Ubuntu VM (10.0.2.X)
- Windows VM (10.0.2.X)
- Kali Linux (10.0.2.X)

Network connection setup:

All the VMs were connected to the NAT Network, ensuring they could communicate with each other during the entire simulation.

3. Environment Validation

● Verify that Security Logs are being generated on the Windows System



```

Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Windows\system32>
PS C:\Windows\system32> Get-WinEvent -LogName Security -MaxEvents 10 | Format-List -Property TimeCreated,Id, Message

TimeCreated : 4/19/2026 11:29:49 AM
Id           : 5379
Message      : Credential Manager credentials were read.

Subject:
  Security ID: S-1-5-21-3509195862-1538831724-1745864665-1001
  Account Name:
  Account Domain:
  Logon ID: 0x52DC1
  Read Operation: Enumerate Credentials

This event occurs when a user performs a read operation on stored credentials in Credential Manager.

TimeCreated : 4/19/2026 11:29:49 AM
Id           : 5379
Message      : Credential Manager credentials were read.

Subject:
  Security ID: S-1-5-21-3509195862-1538831724-1745864665-1001
  Account Name:
  Account Domain:
  Logon ID: 0x52DC1
  Read Operation: Enumerate Credentials

This event occurs when a user performs a read operation on stored credentials in Credential Manager.
  
```

- Running the **Get-WinEvent** command on PowerShell helps us verify that the generated security logs can be read by the Wazuh Agent and transmitted to the Wazuh Server on the Ubuntu machine.

● Ensure Windows produces failed logon events (Event ID: 4625)

```
PS C:\Windows\system32> auditpol /set /subcategory:"Logon" /success:enable /failure:enable
The command was successfully executed.
PS C:\Windows\system32> auditpol /get /subcategory:"Logon"
System audit policy
Category/Subcategory      Setting
Logon/Logoff
    Logon                  Success and Failure
PS C:\Windows\system32>
```

- The command above helps us enable the failed logon events in addition to the successful logon events on Windows. Ensures Wazuh will be able to read failed logon attempts, which is crucial for the root cause analysis

● Check OpenSSH installation on the Windows Machine

```
PS C:\Windows\system32> Get-WindowsCapability -Online | Where-Object Name -like 'OpenSSH*'

Name : OpenSSH.Client~~~~0.0.1.0
State : Installed
Name : OpenSSH.Server~~~~0.0.1.0
State : NotPresent
```

- OpenSSH Client is installed, but the OpenSSH server is not installed.

```
PS C:\Windows\system32> Add-WindowsCapability -Online -Name OpenSSH.Server~~~~0.0.1.0
Path      :
Online    : True
RestartNeeded : False

PS C:\Windows\system32> Get-WindowsCapability -Online | Where-Object Name -like 'OpenSSH*'

Name : OpenSSH.Client~~~~0.0.1.0
State : Installed
Name : OpenSSH.Server~~~~0.0.1.0
State : Installed
```

- OpenSSH server successfully installed on the Windows machine

● Start the OpenSSH service and set it to start automatically on startup

```
PS C:\Windows\system32> Start-Service sshd
PS C:\Windows\system32> Set-Service -Name sshd -StartupType 'Automatic'
```

● Create a firewall rule to accept inbound SSH traffic

```
PS C:\Windows\system32> New-NetFirewallRule -Name sshd -DisplayName 'OpenSSH Server' -Enabled True -Direction Inbound -Protocol TCP -Action Allow -LocalPort 22

Name                : sshd
DisplayName          : OpenSSH Server
Description          :
DisplayGroup         :
Group               :
Enabled             : True
Profile             : Any
Platform            : Any
Direction           : Inbound
Action              : Allow
EdgeTraversalPolicy  : Block
SourceSourceMapping : False
LocalOnlyMapping    : False
Owner               :
PriorityStatus       : OK
Status              : The rule was parsed successfully from the store. (65536)
EnforcementStatus   : NotEnforced
PolicyStoreSource    : PersistentStore
PolicyStoreSourceType : Local
UnsetDynamicValues  :
```

4. Attack Scenario & MITRE Mapping

Phase 1: Reconnaissance (Nmap scanning) [MITRE – T1595: Active Scanning]

The attacker (Kali Linux) performed an aggressive **nmap scan** against the victim (Windows). This was done to identify open ports and confirmed that the OpenSSH service was active and reachable on port 22

```
(kali@kali) [~/Desktop]
$ sudo nmap -v -sC 10.0.2.15
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 06:28 EDT
Nmap scan report for 10.0.2.15
Host is up (0.0029s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH for_Windows_7.7 (protocol 2.0)
|_ ssh-hostkey:
|_ 256 bits RSA
|_ 256 bits ECDSA
|_ 256 bits ED25519
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
5357/tcp   open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Service Unavailable
|_ http-server-header: Microsoft-HTTPAPI/2.0
MAC Address: 08:00:0D:8D:4D:7E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-time:
|_   date: 2026-04-19T21:29:11
|_   start_date: N/A
|_   smb2-security-mode:
|_     3.1.1:
|_       Message signing enabled but not required
|_   _clock-skew: 10h59m56s
|_   _nbstat: NetBIOS name: DESKTOP-9MF7PJ6, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:0D:8D:4D:7E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.07 seconds
```

Phase 2: Brute-Force (Hydra) [MITRE – TA0006: Credential Access]

Using Hydra, the attacker launched a **dictionary-based brute force attack**. This tool was run against a customized list of passwords. It generated multiple rapid authentication attempts in a short window of time

```
(kali@kali) [~/Desktop]
$ hydra -l root -P pass.txt 10.0.2.15 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-19 06:35:24
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 9 tasks per 1 server, overall 9 tasks, 9 login tries (1:1/p:9), ~1 try per task
[DATA] attacking ssh://10.0.2.28:22/
[22][ssh] host: 10.0.2.15 login: root password: root
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-19 06:35:29
```

Phase 3: Successful Exploitation (Credential Compromise) [MITRE – T1021/004: Remote Services: SSH]

The brute-force tool successfully identified the valid credentials. The attacker used these credentials to establish a **remote SSH session**. This granted the attacker initial access to the Windows environment via the Command-Line Interface.

```
(kali@kali) [~/Desktop]
$ ssh root@10.0.2.15
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
root@10.0.2.15's password:
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

al@DESKTOP-9MF7PJ6 C:\Users\al>whoami
desktop-9MF7PJ6

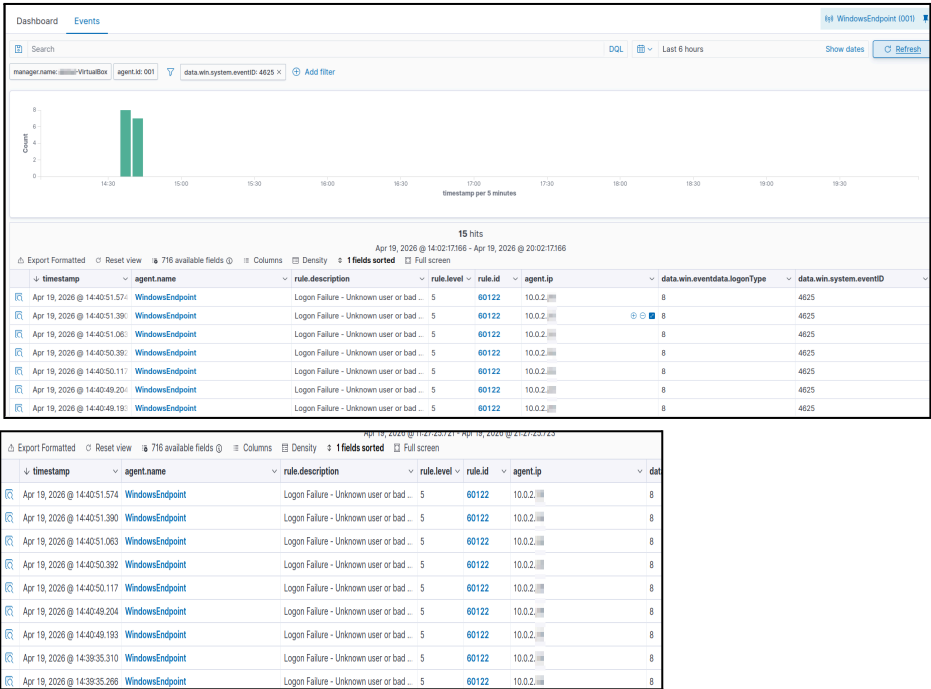
al@DESKTOP-9MF7PJ6 C:\Users\al>hostname
DESKTOP-9MF7PJ6
```

5. Log Collection & Monitoring

A service logon event from a non-standard service account indicates an unexpected or unknown user. This is a strong indicator that the machine has been compromised.

t	input.type	log
t	location	EventChannel
t	manager.name	VirtualBox
t	rule.description	Service logon event registered from non standard service account.
#	rule.firedtimes	1
t	rule.groups	windows, WEF
t	rule.id	67024
#	rule.level	3
🔍	rule.mail	false
📅	timestamp	Apr 19, 2026 @ 14:34:36.515

At **14:39:33**, a series of failed login attempts was observed. The Logon Type 8 alert indicates that the SSH service passed the compromised credentials to the Windows subsystem for authentication, but in this instance, was rejected.

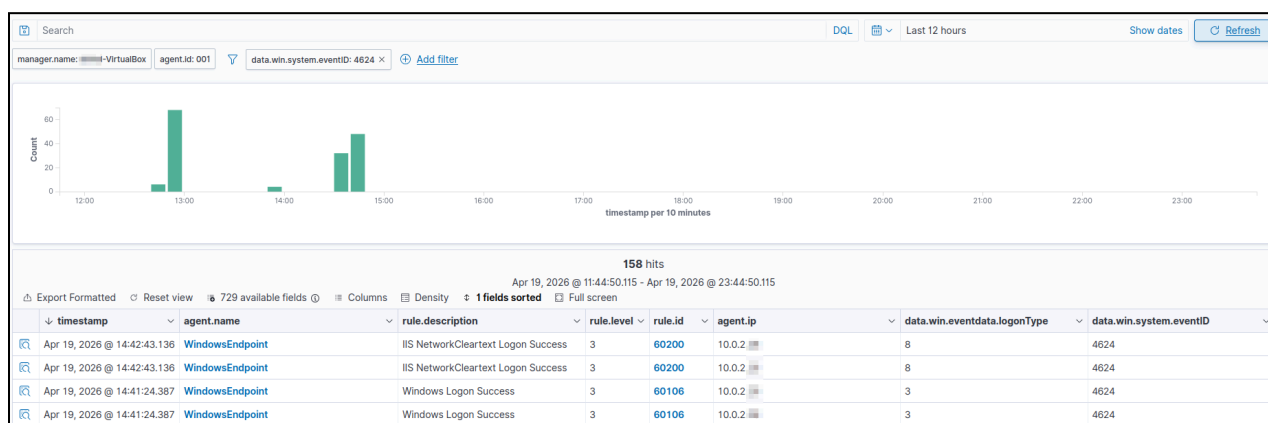


data.win.eventdata.logonType	8
data.win.eventdata.processId	0x17e0
data.win.eventdata.processName	C:\Windows\System32\OpenSSH\sshd.exe
data.win.eventdata.status	0xc000006d
data.win.eventdata.subStatus	0xc0000064
data.win.eventdata.subjectDomainName	WORKGROUP
data.win.eventdata.subjectLogonId	0x3e7
data.win.eventdata.subjectUserName	DESKTOP-██████
data.win.eventdata.subjectUserSid	S-1-5-18
data.win.eventdata.targetDomainName	DESKTOP-██████
data.win.eventdata.targetUserName	NOUSER
data.win.eventdata.targetUserSid	S-1-0-0
data.win.eventdata.workstationName	DESKTOP-██████
data.win.system.channel	Security

Several indicators of brute force can be observed from the above log entry:

- The value of **data.win.eventdata.processName** shows openssh.exe was the process reporting the failed logon attempt. This indicates the attacker explicitly attempted to log in to SSH but failed.
- The value of **data.win.eventdata.status** and **data.win.eventdata.substatus** indicate the attacker was trying to connect with usernames that do not exist on the system. This is a strong indicator of a brute force attack.
- The **TargetUsername** 'NOUSER' is an indicator that this is an invalid account, most probably one that is performing a brute force attack on the victim.

At **14:40:46**, '**Windows Logon Success**' is observed. This indicates that the attacker successfully logged in to the SSH session on the victim machine. The **logon type '3'** indicates a standard Network Logon. An indicator of a remote connection established to the victim host (Windows)



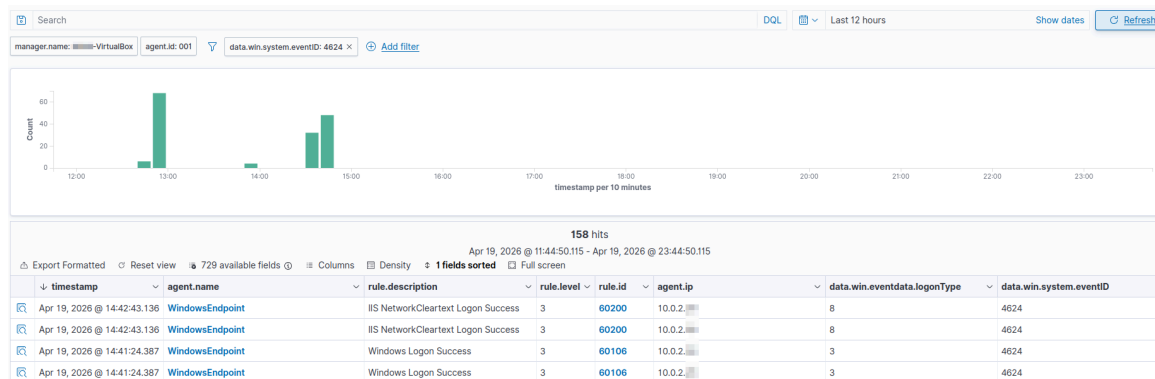
Document Details

View surrounding documents View single document

data.win.eventdata.targetos	5-1-5-21-3509195862-1538831724-1745864665-1801
rSid	
data.win.eventdata.virtualId	\\1843
count	
data.win.system.channel	Security
data.win.system.computer	DESKTOP-...
data.win.system.eventID	4624
data.win.system.eventRecordID	6515
data.win.system.keywords	0x8020000000000000
data.win.system.level	0
data.win.system.message	New Logon: Security ID: 5-1-5-21-3509195862-1538831724-1745864665-1801 Account Name: ... Account Domain: ... Logon ID: 0x68485A Linked Logon ID: ... Network Account Name: ...
data.win.system.opcode	0
data.win.system.processID	668
data.win.system.providerId	{54849625-5478-4994-x86a-9a3b8328c38d}
data.win.system.providerName	Microsoft-Windows-Security-Auditing
data.win.system.severityValue	AUDIT_SUCCESS
data.win.system.systemTime	2026-04-19T21:35:25.4838486Z
data.win.system.task	12544
data.win.system.threadID	720

rule.description	Windows Logon Success
rule.firedtimes	4
rule.gdpr	IV.32.2
rule.gpg13	7.1, 7.2
rule.groups	windows, windows_security, authentication_success
rule.hipaa	164.312.b
rule.id	60106
rule.level	3
rule.mail	false
rule.mitre.id	T1078
rule.mitre.tactic	Defense Evasion, Persistence, Privilege Escalation, Initial Access
rule.mitre.technique	Valid Accounts
rule.nist_800_53	AU.14, AC.9
rule.pci_dss	10.2.5
rule.tsc	CC6.8, CC7.2, CC7.3
timestamp	Apr 19, 2026 @ 14:48:49.853

At **14:42:43**, an **'IIS Network Cleartext'** alert is seen. This indicates network authentication taking place and that the attacker was able to provide the correct password to SSH into the victim host.



All of the above events indicate a successful SSH brute force on the victim machine, and that initial access has been established by the attacker. The attacker could further this compromise by performing a data exfiltration attack, which could allow critical system information to be stolen.

6. Root Cause Analysis

After carefully analyzing and correlating the generated Windows logs via the Wazuh server, it can be concluded that this compromise was possible due to the following reasons:

1. The OpenSSH service was exposed on a standard port (22). This enabled the attacker to successfully exploit the victim machine's vulnerability and compromise the session.
2. OpenSSH on the Windows machine had allowed inbound requests from any IP address by the firewall rules.
3. Password-based authentication was used instead of requiring SSH keys to log in.
4. No account lockout policy or rate limiting was implemented, allowing unrestricted authentication attempts. Even with a minimal password list, the attacker was able to repeatedly attempt logins without interruption, resulting in a successful credential compromise.

7. Indicators of Compromise (IOCs)

Type	Indicator	Description
IP Address (Attacker)	10.0.2.X	Source of nmap scan and brute-force attack
Username	NOUSER	Invalid account guessing indicator
Process	sshd.exe	Source process for all authentication events
Timestamp (Burst Activity)	14:39:33 – 14:40:45	Indicates multiple failed login attempts in a short interval
Event Pattern	Type 8 Success	Indicates successful credential entry via the network

8. Recommendations & Mitigations

The following mitigations can be followed to avoid SSH brute-force attacks:

- Disable password authentication. Enable SSH key authentication, which is a much more secure cryptographic technique for authentication
- Implement brute-force protection, such as Fail2ban. It logs failed attempts and automatically bans suspicious IPs.
- Implement 2-Factor Authentication
- Enforcing strong passwords (Min. 12+ characters) can significantly weaken the 'guess' factor and make it harder for attackers to crack
- Limit authentication attempts by reducing the `MaxTries` value to a lower number.
- Disable Root Login by setting `PermitRootLogin no`. This prevents attackers from targeting or gaining access to the most powerful account on the system.
- Change the standard port (22) to a non-standard port. This helps reduce automated scanning by attackers. However, it should not be relied on as a primary security control.